B BISA GYM ACCESS

DOKUMEN PENJELASAN APLIKASI

BISAGYM
Face Access

Sistem web lokal untuk administrasi member, pengelolaan membership, pendaftaran wajah, dan kontrol akses gym dengan pengenalan wajah.

VERSI DOKUMEN	TANGGAL	STATUS
1.0	**27 Juli 2026**	**Development Demo**

RINGKASAN DOKUMEN

Tentang BISAGYM

BISAGYM adalah aplikasi web lokal yang membantu pusat kebugaran mengelola proses administrasi keanggotaan dan pemeriksaan akses pintu dalam satu sistem. Aplikasi menggabungkan data member, masa berlaku membership, persetujuan biometrik, profil wajah, perangkat kiosk, keputusan akses, dan audit log.

01

Administrasi Terpadu

Data member, paket, periode membership, pengguna, cabang, perangkat, dan laporan dikelola melalui dashboard berbasis peran.

02

Akses Berbasis Wajah

Kiosk memeriksa wajah, kualitas, liveness, identitas, membership, cabang, perangkat, dan cooldown sebelum memberi keputusan.

03

Privasi dan Audit

Enrollment memerlukan consent aktif. Perubahan penting, override, pencabutan consent, dan pengaturan sensitif dicatat.

04

Demo Tanpa Hardware

Adapter mock memungkinkan seluruh alur utama diuji tanpa webcam, model biometrik, kamera depth, atau relay pintu fisik.

> **Tujuan utama**
>
> Memastikan hanya member yang dikenali, aktif, berada pada cabang yang benar, dan tidak sedang terkena cooldown yang dapat memperoleh keputusan akses `ALLOW`.

Isi Dokumen

1 **Tujuan dan manfaat**

2 **Peran pengguna**

3 **Fitur aplikasi**

4 **Alur operasional**

5 **Arsitektur sistem**

6 **Aturan akses**

7 **Keamanan dan privasi**

8 **Cara menjalankan**

9 **Panduan demo**

10 **Pengujian dan batasan**

01 / TUJUAN DAN MANFAAT

Masalah yang Diselesaikan

Pemeriksaan membership secara manual dapat memperlambat antrean, menghasilkan pencatatan yang tidak konsisten, dan menyulitkan pelacakan keputusan akses. BISAGYM membuat proses tersebut terstruktur dan dapat diaudit.

Lebih Cepat

Kiosk memberikan umpan balik langsung dan memisahkan pemeriksaan biometrik dari validasi membership.

Lebih Tertib

Status aktif, kedaluwarsa, ditangguhkan, dibatalkan, dan belum dimulai dihitung secara konsisten.

Lebih Terukur

Check-in, penolakan, perangkat, override, dan aktivitas operator dapat dipantau melalui laporan.

Sasaran Pengguna

PENGGUNA	KEBUTUHAN	MANFAAT BISAGYM
Pengelola gym	Kontrol organisasi dan keamanan	Dashboard, cabang, pengguna, pengaturan, perangkat, audit, dan laporan.
Resepsionis	Pelayanan member sehari-hari	Pencarian, pendaftaran, membership, enrollment, dan override manual.
Member	Check-in yang cepat dan jelas	Kiosk berbahasa Indonesia dengan status akses yang mudah dipahami.
Tim teknis	Operasi dan pemeliharaan	Health endpoint, konfigurasi environment, migrasi, seed, test, dan Docker Compose.

Prinsip Produk

- OK Keputusan akses tidak hanya bergantung pada kecocokan wajah.
- OK Penolakan biometrik tidak diam-diam diganti oleh override manual.
- OK Data wajah diperlakukan sebagai data sensitif dan tidak ditampilkan sebagai embedding mentah.
- OK Kegagalan backend menyebabkan akses ditolak, bukan diberikan secara otomatis.
- OK Alternatif non-biometrik melalui resepsionis tetap tersedia.

02 / PERAN PENGGUNA

Kontrol Akses Berbasis Peran

Setiap akun staf memiliki hak akses yang ditegakkan pada backend. Menyembunyikan menu pada frontend hanya membantu pengalaman pengguna; keamanan sebenarnya tetap berada pada API.

PERAN	HAK UTAMA	PEMBATASAN PENTING
Super Admin	Semua cabang, pengguna, perangkat, pengaturan, laporan, audit, dan penghapusan biometrik.	Perubahan sensitif tetap dicatat dan memerlukan autentikasi.
Gym Admin	Member, paket, membership, enrollment, perangkat, check-in, dan laporan pada cabangnya.	Tidak dapat mengubah pengaturan keamanan global atau cabang lain.
Resepsionis	Mencari dan membuat member, membership, enrollment, check-in, dan override manual.	Tidak dapat mengelola pengguna, perangkat, atau threshold global.
Kiosk Device	Membuat sesi, mengirim percobaan check-in, menerima keputusan, dan heartbeat.	Merupakan identitas mesin, bukan akun manusia; memakai autentikasi perangkat.

> **Prinsip least privilege**
>
> Pengguna hanya memperoleh akses minimum sesuai tugas. Data cabang diperiksa kembali oleh backend pada setiap operasi penting.

Akun Demo

PERAN	EMAIL	PASSWORD DEVELOPMENT
Super Admin	`superadmin@gym.local`	`GymDemo123!`
Gym Admin	`admin@gym.local`	`GymDemo123!`
Resepsionis	`reception@gym.local`	`GymDemo123!`

Kredensial ini hanya untuk development. Deployment produksi wajib memakai password dan secret unik serta tidak menjalankan seed demo.

03 / FITUR APLIKASI

Modul Administrasi

Dashboard

Menampilkan jumlah member aktif, check-in berhasil, akses ditolak, perangkat online, dan aktivitas terbaru dari API.

Data Member

Pencarian, filter, pembuatan, edit, soft delete, detail profil, kontak darurat, dan catatan.

Paket Membership

Membuat dan mengubah nama, durasi, harga, deskripsi, status paket, serta daftar membership yang segera berakhir.

Membership

Menetapkan paket, memperpanjang, menangguhkan, mengaktifkan kembali, membatalkan, dan melihat riwayat.

Pendaftaran Wajah

Consent eksplisit, sesi enrollment, panduan pose depan-kiri-kanan, simulasi liveness, dan aktivasi profil.

Riwayat Akses

Waktu, member, perangkat, hasil, alasan, waktu proses, serta override manual yang dicatat terpisah.

Perangkat

Registrasi kiosk, kapabilitas RGB/depth/liveness, status aktif, heartbeat, dan rotasi kredensial satu kali tampil.

Laporan

Kehadiran, alasan penolakan, membership berakhir, kesehatan perangkat, dan ekspor CSV terautentikasi.

Pengaturan

Threshold, kualitas minimum, liveness, depth, cooldown, retensi, dan versi pemberitahuan privasi.

Pengguna dan Cabang

Super Admin dapat membuat cabang dan akun operator beserta peran dan cakupan cabangnya.

Kiosk Check-in

Kiosk menyediakan pratinjau kamera jika tersedia, instruksi posisi, indikator koneksi, pemberitahuan privasi, hasil besar berkontras tinggi, dan alternatif check-in manual.

Hasil Diizinkan

Nama ditampilkan secara terbatas, masa berlaku membership, waktu check-in, dan pesan akses diberikan.

Hasil Ditolak

Pesan netral seperti membership berakhir, wajah belum dikenali, atau liveness gagal. Skor biometrik tidak ditampilkan.

04 / ALUR OPERASIONAL

Alur Member dan Enrollment

LANGKAH 1
Buat atau pilih member.

›

LANGKAH 2
Tetapkan paket dan periode.

›

LANGKAH 3
Rekam consent biometrik.

›

LANGKAH 4
Daftarkan sampel wajah.

1. Petugas membuka Data Member dan memverifikasi identitas.
2. Paket membership dipilih. Backend menghitung akhir periode berdasarkan durasi paket.
3. Pernyataan consent menjelaskan tujuan, retensi, akses, pencabutan, dan alternatif non-biometrik.
4. Sesi enrollment memiliki batas waktu dan meminta pose depan, kiri, serta kanan.
5. Adapter biometrik memeriksa jumlah wajah, kualitas, liveness, dan depth bila diwajibkan.
6. Profil dibuat dengan metadata nama serta versi model. Embedding tidak dikirim ke browser.
7. Aktivitas enrollment dicatat pada audit log.

> **Mode mock tanpa kamera**
> Jika webcam tidak tersedia, tombol sampel mock tetap memungkinkan pengujian alur development. Antarmuka menandai bahwa hasil berasal dari simulasi.

Pencabutan Data Biometrik

Member dapat mencabut consent. Sistem menandai consent sebagai revoked dan menonaktifkan profil wajah aktif. Alasan, operator, waktu, dan resource terkait dicatat tanpa menghapus audit historis.

04 / ALUR OPERASIONAL

Alur Check-in Kiosk

CAPTURE
Sesi dan challenge dibuat.

›

RECOGNIZE
Kualitas, liveness, identitas.

›

VALIDATE
Member, membership, device.

›

DECIDE
ALLOW atau DENY.

State Machine

```
IDLE → CAMERA_READY → FACE_DETECTED → QUALITY_VALIDATED
→ LIVENESS_VALIDATED → EMBEDDING_EXTRACTED → IDENTITY_MATCHED
→ MEMBERSHIP_VALIDATED → ACCESS_GRANTED / ACCESS_DENIED
→ COOLDOWN → IDLE
```

Setiap transisi menghasilkan telemetry terstruktur. Pemisahan state machine mencegah seluruh aturan bisnis ditumpuk pada satu route handler.

Manual Override

1. Percobaan biometrik yang gagal tetap tersimpan sebagai `DENY`.
2. Resepsionis memilih member terdaftar dan memasukkan alasan verifikasi.
3. Sistem membuat percobaan baru dengan `ALLOW` dan `MANUAL_OVERRIDE`.
4. Identitas operator, alasan, waktu, dan referensi percobaan awal dicatat.

> **Fail closed**
> Ketika backend atau perangkat tidak siap, sistem tidak memberikan akses otomatis. Member diarahkan ke resepsionis.

05 / ARSITEKTUR SISTEM

Komponen dan Teknologi



LAPISAN	TEKNOLOGI	TANGGUNG JAWAB
Frontend	React, TypeScript, Vite, React Router, TanStack Query, Zod	Antarmuka responsif, validasi form, kamera browser, state server, dan role navigation.
Backend	Python 3.13, FastAPI, Pydantic, SQLAlchemy	Autentikasi, RBAC, aturan membership, state machine, audit, report, dan API.
Database	PostgreSQL/pgvector; SQLite development	Data operasional, membership, template sensitif, check-in, dan audit.
Migrasi	Alembic	Membuat dan memperbarui schema database secara terkontrol.
Biometrik	Adapter interface dan mock deterministic	Deteksi, kualitas, liveness, embedding, dan pencocokan tanpa mengikat satu vendor.
Infrastruktur	Docker Compose	Service web, API, PostgreSQL, health checks, dependency startup, dan volume.

Struktur Repository

```
BISAGYM/
├─ apps/web/          Frontend React
├─ apps/api/          FastAPI, migration, seed, tests
├─ docker/            Dockerfiles dan API entrypoint
├─ docs/              Dokumentasi teknis dan pengguna
├─ docker-compose.yml
├─ tasks.ps1          Perintah Windows
└─ IMPLEMENTATION_STATUS.md
```

06 / ATURAN AKSES

Keputusan ALLOW dan DENY

Akses hanya diberikan jika seluruh pemeriksaan wajib berhasil. Satu kegagalan menghasilkan kode alasan yang stabil agar kiosk, laporan, dan audit memberikan arti yang konsisten.

Syarat Akses Diberikan

- Tepat satu wajah valid.
- Kualitas gambar melewati batas.
- Liveness berhasil.
- Identitas melewati threshold.
- Member dan membership aktif.
- Waktu berada dalam periode membership.
- Device dan cabang aktif serta sesuai.
- Tidak berada dalam cooldown.

Status Membership

ACTIVE Berlaku saat ini.

PENDING Belum mencapai waktu mulai.

EXPIRED Waktu akhir telah terlewati.

SUSPENDED Ditangguhkan oleh petugas.

CANCELLED Dibatalkan dan tidak dapat dipakai.

Kode Penolakan Utama

KATEGORI	KODE	MAKNA
Wajah	`NO_FACE`, `MULTIPLE_FACES`, `LOW_IMAGE_QUALITY`	Tangkapan tidak memenuhi syarat dasar.
Liveness	`LIVENESS_FAILED`	Challenge atau pemeriksaan anti-spoof gagal.
Identitas	`IDENTITY_NOT_FOUND`, `LOW_MATCH_CONFIDENCE`	Profil tidak ditemukan atau skor di bawah threshold.
Membership	`MEMBERSHIP_NOT_STARTED`, `MEMBERSHIP_EXPIRED`, `MEMBERSHIP_SUSPENDED`	Periode atau status membership tidak mengizinkan akses.
Perangkat	`DEVICE_INACTIVE`, `BRANCH_MISMATCH`	Perangkat tidak aktif atau cabang tidak sesuai.
Frekuensi	`DUPLICATE_CHECKIN`	Member masih berada dalam cooldown.

07 / KEAMANAN DAN PRIVASI

Perlindungan Data

Autentikasi Staf

Password Argon2, JWT access token, refresh token rotation, session revocation, rate limiting, dan role check backend.

Autentikasi Device

Kode dan secret perangkat, challenge session singkat, token satu kali, serta idempotency key.

API Security

CORS eksplisit, secure headers, correlation ID, validasi input, ORM parameterized query, dan error terstruktur.

Prinsip Biometrik

- OK Consent aktif diwajibkan sebelum enrollment.
- OK Raw capture storage dinonaktifkan secara default.
- OK Embedding tidak dikirim ke frontend dan tidak boleh masuk log.
- OK Pencabutan consent menonaktifkan profil aktif.
- OK Nama model dan versi preprocessing disimpan bersama profil.
- OK Threshold produksi harus dikalibrasi dengan kondisi lokasi nyata.

Audit yang Dicatat

Login berhasil/gagal, pembuatan dan perubahan member, perubahan membership, consent, enrollment, pencabutan, perubahan threshold, perangkat, override manual, ekspor laporan, dan workflow penghapusan.

Larangan data sensitif

Jangan menaruh foto wajah, embedding, model weights, access token, password, atau secret perangkat pada log, repository, folder publik, maupun file ekspor.

HTTPS produksi

Localhost dapat memakai HTTP untuk development. Deployment jaringan wajib memakai TLS, secret unik, backup terenkripsi, retensi log, dan kontrol akses operasional.

08 / CARA MENJALANKAN

Development Lokal Windows

Prasyarat

- Python 3.13 atau versi yang sesuai metadata backend.
- Node.js 20 atau lebih baru dan npm.
- PowerShell 5.1 atau lebih baru.
- Port 5173 dan 8000 tersedia.

Instalasi dan Persiapan

```
cd "D:\1. TUGAS UTAMA NEGARA\BISAGYM"
./tasks.ps1 install
./tasks.ps1 migrate
./tasks.ps1 seed
./tasks.ps1 dev
```

Alamat Aplikasi

LAYANAN	ALAMAT
Web Admin	`http://127.0.0.1:5173`
Kiosk	`http://127.0.0.1:5173/kiosk`
Backend API	`http://127.0.0.1:8000`
Dokumentasi OpenAPI	`http://127.0.0.1:8000/docs`
Health Readiness	`http://127.0.0.1:8000/health/ready`

Menjalankan dengan Docker

```
Copy-Item .env.example .env
docker compose up --build
docker compose exec api python -m app.seed
```

Docker Compose menyediakan service `web`, `api`, dan `postgres` dengan health checks dan volume PostgreSQL persisten.

> **Catatan lingkungan saat dokumen dibuat**
> Docker Compose telah disiapkan tetapi belum diuji pada komputer ini karena Docker belum terpasang.

09 / PANDUAN DEMO

Skenario Tanpa Hardware

Mode default menggunakan backend nyata dengan `FACE_ENGINE=mock`. Data tetap diproses dan dicatat oleh API, tetapi hasil pengenalan berasal dari tag deterministik, bukan wajah manusia.

KONTROL KIOSK	TAG INTERNAL	HASIL
Member aktif	`member-demo-active`	ALLOW Membership aktif.
Kedaluwarsa	`member-demo-expired`	DENY Membership berakhir.
Ditangguhkan	`member-demo-suspended`	DENY Membership suspended.
Tidak dikenal	`unknown`	DENY Identitas tidak ditemukan.
Spoof	`spoof`	DENY Liveness gagal.

Urutan Demonstrasi

1. Login sebagai `admin@gym.local`.
2. Buka Dashboard untuk melihat data hasil seed.
3. Buka Data Member dan periksa member aktif, kedaluwarsa, suspended, dan tanpa wajah.
4. Buka Pendaftaran Wajah, pilih member tanpa wajah, rekam consent, lalu gunakan sampel mock.
5. Buka Kiosk dan jalankan lima kontrol simulasi hasil.
6. Buka Riwayat Akses untuk melihat percobaan yang baru dicatat.
7. Pada percobaan DENY, lakukan override manual dengan alasan yang jelas.
8. Login sebagai Super Admin untuk melihat Pengaturan, Pengguna, dan Cabang.
9. Buka Laporan dan unduh CSV attendance.

> **DEMO MODE terlihat**
> Badge dan kontrol simulasi tidak disembunyikan agar operator tidak menganggap adapter mock sebagai teknologi pengenalan wajah produksi.

10 / API DAN DATA

Kontrak API Utama

Seluruh endpoint aplikasi menggunakan prefix `/api/v1`. Dokumentasi interaktif tersedia melalui OpenAPI.

MODUL	ENDPOINT UTAMA
Autentikasi	`POST /auth/login`, `POST /auth/refresh`, `GET /auth/me`
Member	`GET/POST /members`, `GET/PATCH/DELETE /members/{id}`
Membership	`GET/POST /members/{id}/memberships`, suspend, reactivate, cancel
Consent	`POST /members/{id}/biometric-consents`, revoke consent
Enrollment	Create session, upload sample, complete session, revoke profile
Kiosk	Create session, check-in, status attempt, heartbeat
Operasional	Check-ins, manual override, dashboard summary, devices
Pelaporan	Attendance, denials, expiring memberships, device health, CSV
Sistem	Settings, branches, users, audit logs, health endpoints

Entitas Database

Schema utama terdiri dari branches, users, members, membership plans, memberships, biometric consents, face profiles, enrollment samples, devices, kiosk sessions, check-in attempts, access events, audit logs, system settings, dan auth sessions.

> **Identitas member bukan data biometrik**
>
> Member memiliki UUID dan kode member. Template wajah merupakan profil tambahan yang dapat dicabut tanpa menghilangkan identitas utama atau histori membership.

Hasil Verifikasi

16
Backend Tests
Aturan membership, RBAC, check-in, enrollment, revocation, CSV, device, dan setting.

11
Frontend Tests
Login, role navigation, member, enrollment, kiosk, setting, perangkat, dan paket.

200
HTTP Status
Web dan health API terverifikasi merespons sukses pada proses lokal.

Pemeriksaan yang Lulus

- OK Pytest backend: 16 test lulus.
- OK Vitest frontend: 11 test lulus.
- OK Ruff lint dan format check lulus.
- OK ESLint dan TypeScript type-check lulus.
- OK Vite production build lulus.
- OK Alembic migration dari database kosong lulus.
- OK Seed menghasilkan 3 akun, 1 cabang, 4 paket, 4 member, dan 1 kiosk.
- OK Smoke test login, member, kiosk, report, setting, pengguna, cabang, dan perangkat lulus.

Status Implementasi

Foundation, membership management, mock biometric workflow, dashboard, perangkat, report, setting, pengguna, cabang, audit, dan dokumentasi telah tersedia. Status rinci dan checklist jujur disimpan pada `IMPLEMENTATION_STATUS.md`.

12 / BATASAN DAN PENGEMBANGAN

Yang Masih Memerlukan Produksi Nyata

Model Pengenalan Wajah

Adapter ONNX, detector, alignment, embedding extractor, vector index, dan dataset validasi belum diaktifkan sebagai model produksi.

Liveness Production-grade

Challenge mock bukan jaminan anti-spoof. Produksi memerlukan landmark tracking atau PAD model yang tervalidasi.

Kamera Depth RGB-D

Integrasi memerlukan device service lokal, SDK vendor, sinkronisasi frame, kalibrasi, dan validasi depth.

Door Relay

Controller fisik belum dihubungkan. Browser tidak boleh menyalakan relay secara langsung.

Deployment Production

TLS, secret manager, backup terenkripsi, restore drill, monitoring, shared rate limiter, dan log retention perlu dikonfigurasi.

Kalibrasi Lapangan

Threshold wajib dipilih menggunakan data kamera, pencahayaan, jarak, dan populasi cabang yang sebenarnya.

Gerbang lisensi model

Sebelum penggunaan komersial, lisensi source code dan pretrained weights harus diverifikasi secara terpisah. Model tidak boleh didistribusikan atau dipakai secara komersial bila izinnya tidak jelas.

Rekomendasi Tahap Berikutnya

1. Pilih model yang memiliki izin komersial dan dokumentasikan sumber serta versinya.
2. Bangun dataset evaluasi dengan consent pada kondisi cabang yang nyata.
3. Ukur false accept, false reject, latency, dan performa liveness.
4. Implementasikan HTTPS, rotasi secret, backup, restore, dan observability.
5. Uji end-to-end menggunakan browser serta perangkat kiosk target.
6. Lakukan penilaian privasi dan keamanan sebelum go-live.